M T W T F S

DATE:

CS205 - Information Security

Topic 01:

Definition of Information Security

Protecting information & information system (device) from unauthorized access, use, disclosure, disruption, modification or destruction.

For example: SANS

Q: Differentidate between IT security & Information security?

Information Technology Security (IT security)	Information Security (Info Sec
✓ It is information security applied to technology.	Information security also covers physical security, human resource security, legal & compliance, organiz-ational and process related aspects:
✓ It is a part of Information security.	• Governance
IT Security Functions	• Polices & Procedures
• Network Security	• Risk Management
• System Security	• Perfomance Reviews
• Mobile Security	
• Application & Database Security	

M T W T F S

DATE:

Q: What is Cyber Security?

Protecting Information and information systems from unauthorized access, use dislosure, disruption, modification, or destruction through internet.

- Prevention of crime related to internet. we taken help from cyber security.

Main Parts of Infosec: (Long Question)

- Three Pillars of Information Security:

1- Confidentiality:

Keeping information secret

Infosec میں صرف مختص لوگوں کو علم ہونا چاہیئے اس کے لیے یہ والی type کا استعمال کرتے ہیں۔

- Don't out the secrets

2- Integrity:

Keeping information in its original form.

اس type میں data کو اصلی شکل میں اپنے پاس محفوظ کرتے ہیں۔ اور آگے کسی کو بھی share نہیں کرتے۔

- Don't add any illegal/irrelevant data.

3- Availability:

Keeping information & information systems available for use.

اس میں information ایک مخصوص وقت میں ہی Available ہونی چاہیئے۔

Topic :02

Why is Information Security Needed?

History why needed:

- Bangladesh Bank SWIF Hack - Feb 2016: MCQs
  Hacker used SWIFT Credentials of Bangladesh Central Bank employee to send more than 3 dozen fraudulent money transfer request.
  MCQs.
  - USD 81 million stolen
  - Total impact could have been ~~used~~ USD 1 billion.

- NHS cyberattack - May 2017 MCQs
  This is "biggest" ransomware outbreak in history.
  Ransomware attack hits 99 countries with UK hospitals among targets - MCQs

The exact answer of why in the Next page.

Who is Information Security for?

کس کے لیے ہے Info securi

For
1- Personal use:

Information security is used for Personal use like as; • social media passwords and safe usage.

- online Banking & email passwords
- Home PC/Laptop & Mobile Security

For
2- Orgranizational:

- Board and executive leadership
- CISO (chief information security officer) ↓ responsible to drive security programs
- IT staff & business users

For
3- Govt and National departements:

- In law enforcement, Legal and policy making.
- In National database, critical infrastructur , Regulation , Standards and certifications , Capacity-building and coordination.

MCQs.

Pakistan ranked almost at the bottom of the table in International ranking by ITU.

MCQs: Pakistan Cyber Security Association (PCSA) formed to address Pakistan's International Ranking.

CS205 - Mid Term - Prepration

For Subjective Part

Q No1: Three pillars of information security?

There are 3 pillars of info security:

1- Confidentiality

2- Integrity

3- Availability

Q No2: What are the challenges of info security?

There are 3 challenges of info-security:

1- Lack of ownership

2- Department silos

3- missing security hardening

Q No 3: Which combination can make information security?

Information Security is combination of "People process" and "technology".

T W T F S DATE:

~~V o V o V o IMP => M t0 s, Short, long~~

Qno4: Write down four Layers of transformation model in sequence?

1- Security Hardening; security controls on IT assets & process.

2- Vulnerability management; Patching

3- Security Engineering; More complex security design and solutions.

4- Security governance; Managing the information security Program.

Qno5: In International ranking by ITU, what's the rank of Pakistan.

Pakistan ranked almost at the "bottom of the table" in international ranking by ITU and Pakistan rank is 67th.

→ In small sized security organization in Pakistan, It is likely the number of security stall will be 1-5 or 2-4.

→ Medium sized: 10-15 persons

→ Large sized: 30 persons

Qno6: What was the old name ISO27002:2013?

ISO1799

W T F S DATE:

Q No 6: What is information Security By SANS

Answer:

Protecting information (information) & info systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Q No 7: What is "Security hardening" Define?

Answer:

Security Hardening is the process of configuring the IT assets to maximize ~~the~~ security of the IT assets and minimize security risks.

Q No 8: Write any five steps in information security Programs:

1- Assessing security risks and gaps.
2- Implementing security controls
3- Monitoring, measurement, & analysis
4- Mangement reviews and internal adult (adult)
5- Accreditation / Testing

Q No 9: Steps in Security Engineering (Imp)

1- Assess risk profile

2- Research security solutions

3- Design security architecture

4- Implementation Security Controls & Solutions

5- Test and validate security posture

M T W T F S DATE:

Q No 10: Secure Shell (SSH) Protocols Version names?

Secure Shell (SSH) supports 2 different and incompatible protocols:

1- SSH1: It was the original protocol and it was subject to security issues. MCQs

2- SSH2: It was more "advance" and "secure". MCQs

Q No 11) Info Security Governance ~~Book~~ Block? How many?

There are 3 blocks of information security in Governance Block.

1- Initial Block (in which includes)

- Policy
- Responsibility
- Periodic Review
- Recourse & Priority

2- Intermediate Block

- Change Management
- SOP's
- Awareness
- Monitoring

3- Mature Block

- Risk Management
- Internal audit
- Incident Management

M T W T F S DATE:

Q No 12: How to build Effective info security Governance?

Key success factors:

- Leadership
- strategy
- Structure
- Reporting
- Project management
- Culture

Q No 13: What are some of the common vulnerability scanners?

Commonly used ~~scaln~~ vulnerability Scanners are:

1- Open VAS
2- Nessus
3- Qualys
4- Rapid 7

Q No 14: Free tool offered by Qualys?

1- Browser Check
2- SSL

Q No 15: Free scan of Qualys?

1- Vulnerability
2- OWASP
3 Patch Tuesday
4- SCAP

M T W T F S DATE:

Qno15: What are the steps In VM Lifecycle? (Velnurability-Management)

VM steps are:

1- Analyze assets
2- Prepare Scanner
3- Run Vulnerability Scan
4- Assess results
5- Patch Systems
6- Verify (re-scan)

Qno16: Write some pre-requisites For Security Hardening?

Pre-requisites for Security Hardening are:

1- Security Program approved
2- Consultant on board
3- Project kick-off meeting held
4- ISMC team identified and their Loading for this Project communicated.
5- Appraisal linkage of core resources announced by CIO.

Qno17: Types of Security Testing?

There are four types of Security Testing:

1- Vulnerability Assessment (VA)
2- Penetration Testing (PT)
3- Other security tests through various automated tools.
4- Code review [initiated in test environment]

M T W T F S

DATE:

Q.No 18: Which vulnerability scanner is used to look for both code based and configure based vulnerability?

Use a SCAP, it is validated velnurability scanner that looks for both code-based velnurabilities and configuration based velnurability.

Q.No 19: In the Qualys Guard scanning methodology once TCP port scanning has been performed mention the detection test?

OS detection detects the Qualys Guard scanning methodology.

Q.No 20: What is Security Validation?

Security validation means to confirm via walk-Through of system or device that the security controls implemented by an IT team have actually been implemented correctly.

Q.No 21: What is a Patch?

A Patch is a piece of software designed to update a computer program or its supporting data, to fix or improve it. This includes "fixing security vulnerability ~~information~~ & other bugs.

M T W T F S DATE:

Q No 22. What are general steps for patch management? 3-steps

1- Establish baseline IT assets inventory

2- Gather software patch and vulnerability info

3- Identify vulnerability relevancy & filter to assign to end point.

Q No 23: Who implements the security controls?

Under the security transformation model, security controls are implemented by the IT teams.

Q No 24: Who conduct security validation?

Security validation by the information security team or by a third party consultant.

Q No 25: Why do we need to validate security controls?

- To check the completeness of the controls
- To check the correctness of the controls
- As an overall assurance

Q No 26: Mention any 2 factors behind insecure software.

1- Connectivity 2- Extensibility

3- Complexity

M T W T F S DATE:

Q.No27: Write any five activities performed in accreditation process.

1- Organize
2- Prepare Checklist
3- Confirm Tests
4- Documentation & Process
5- Team Meeting
6- Issue Accreitation

Q.No28: What is Disaster? (تباہی/المیہ)

Any significant event that causes disruption of information technology processing facilities, thus affecting the operations of the business.

Q.No29. What is Disaster Recovery? (DR)

Disaster Recovery is an area of security that allows an organization to maintain or quickly resume mission critical (IT) functions following a disaster.

Q.No30: What type of assets do not have a CIS/DISA STIG?

- Software Applications (ASP, NET, PHP, other)
- Other Applications such as asterisk deployments.

M T W T F S DATE:_____

Qno 31: V.V.V. IMP table

Re-arrange ⟨ ⟩ ka. A jata ha. Or Likhny k lya bhi- like last column blank hu ga, khud likhna hu ga.

Initial Block Table

	Activity	Responsible	Detail
1-	Policy	Developed by CISCO signed off by board/ executive	Sets the scope, objectives, frame-work, requirements.
2-	Responsibility & Authority	Board/Executive	Assigns roles, responsibility & authority for info-security Programs
3-	Resource Assignment & Priority setting	Board/Executive	Allocation for resources & budget for the info-security functions
4-	Periodic Review	Board / Executive	Monitor and review that the goals of the info sec Program are being met.

M T W T F S

DATE:

Q No 32: Write down typical security tools used in an enterprise:

- Enerprise Antivirus
- MS Active Directory
- Vulnerability Management
- logs Management
- Network and performance monitoring
- Automated Backups

Q No 33. Major Components of Enterprise IT Network:

1- Edge router
2- NGN FW
3- DMZ:
4- NAC
5- IPS & N-DLP
6- Access switch ✓
7- Distribution switch ✓
8- Data center switch & FW ✓

If question come ⟶ Write down switches in Enterprise IT components. You can write these 3 names ↑

Q No 34: CIS benchmark in Profile applicability?

✓ Profile applicability (ASA 8.x, ASA 9.x):

✓ Rationale
✓ Audit
✓ Remediation
✓ Default value
✓ References

Long The OWASP software Assurance Maturity Model (SAMM) undertakes software security testing & validation during the follow

M T W T F S DATE:

Q No 35. Phases of Software Development Phas

life-cycle

Software Development

Software Pevelopement is divided into 4 categories:

1- Governance

- Strategy & Metrics
- Education & Guidance
- Policy & Compliance
-

2- Construction

- Security Requirements
- Threat Assessment
- Secure Architecture

3- Verification

- Design Review
- Security Testing
- Code Review

4- Deployment

- Environment Hardening
- Vulnerability Management
- Operational Enablement

1-
2-
3-
4-

M T W T F S DATE:

Q No 36: Comparison of CIS Vs DISA

Feature	CIS	DISA
Control Coverage	Good	Excellent
ORG Suitability	Small, Medium	Large ORGS
User Friendly	Good	Satisfactory
Unuseable Termindogy	No	Yes
Control Detail	Good	Satisfactory
Tools	CAT (commercial)	SCAP (Military Use)

Q No 37: OWASP Software Assurance Maturity Model (SAMM) Governance Phase:

- Strategy & Metrics
- Education & Guidance
- Policy & Compliance

Q No 38: OWASP ---. Construction Phase:

- Security Requirements
- Threat Assessment
- Secure Architecture

M T W T F S DATE:

Q No 39: OWASP Software Assurance Maturity Model (SAMM) Verification Phase:

- Design Review
- Code Review
- Security Threat Testing

یہ Cover نہیں ہوا Q No 35 میں ہم نے Phase 4 پڑھا ہے۔

Q No 40: What is Bussiness continuity? (BC)

Business continuity (BC) is the capability of the org to continue delivery of products or services at acceptable predefined levels following a disruptive incident.

Q No 41: How web and email can secured againt malware and attacks in enterprise.

To secure web and email in an enterprise, Implement antivirus software, firewalls, and intrusion detection systems.

Train employees on security best practices, use email encryption, update software, employ MFA, monitor traffic, backup data, & conduct security Assessments.

M T W T F S DATE:

Qno 42. Software Security flow?

refers to the systematic process of indentifying, assing and ~~mtgtmngt~~ mitigating security risks and vulnerability in software applications.

Qno 43: Difference between Remote Exploit.

A remote exploit works over a network and exploits the security velnurability without any prior ~~access~~ access to the velunerable system.

Local Exploit:

A local exploit requires prior access to the velnurable system & usually increase the privilleges of the person running the explort past those granted by the system administrator.

Qno Backup Consideration

What to backup? Backup location?

Freq~~ui~~ency of backup? Backup operator?

daily? Backup checker (verification)?

monthly? weekly? Backup tests & security methods?

Technology & tools used for backup?